

Stakeholder Feedback and System Requirements

<https://gemini.google.com/app/7efaa533065c158a>

User prompt: Hey, we keep missing people on the callouts. Half of Local 27 didn't know about Thursday's emergency meeting until it was too late and it's caused real problems with the contractor situation. Members are saying they never got anything, or they got it but by the time they saw it the meeting was already over. Also I need to know before I leave the hall on the day of a callout who is actually coming so I'm not standing in an empty room. Oh and can members outside our local see the wireman apprentices' contact info too? Someone mentioned that during onboarding and I want to make sure that's not happening. We need this sorted before the next round of contract talks, whenever that ends up being scheduled.' Restate what she is actually asking for in plain terms, as if explaining it back to her. Do not design anything yet. Just tell me what you think the three or four separate asks buried in this are, and which ones conflict with each other. For example, immediate delivery versus members being offline for days in basements, shafts, or rural areas with no signal.

Response: Based on your request, here is a breakdown of the core needs and potential conflicts buried in the situation.

1. Reliable Emergency Callout Delivery

You need critical, last-minute notices to reliably reach every member of Local 27 in time, regardless of whether they are working in areas without cellular service (like basements, shafts, or rural sites) or checking their phones long after the event has passed.

2. Real-Time Attendance & Headcount Tracking

You need immediate visibility before leaving the union hall on the day of a callout to know exactly who is attending, giving you an accurate headcount rather than waiting in an empty room.

3. Apprentice Data Privacy & Visibility Control

You need to verify and ensure that sensitive contact information for wireman apprentices is strictly protected and only accessible to authorized members within Local 27, rather than being visible to members of outside locals.

4. Timely System Resolution

You need all of these communication and privacy operational issues resolved and functioning reliably prior to the upcoming contract negotiations.

Key Conflicts Between These Needs

- **Immediate Real-Time Delivery vs. Off-Grid Work Environments:** Expecting immediate delivery and real-time responses directly conflicts with members working in signal-dead zones (basements, shafts, rural locations). Emergency broadcasts cannot force a delivery or response from a device that is offline until the member returns to coverage.
- **Instant Headcounts vs. Delayed Member Read Time:** Demanding an immediate headcount at the hall assumes members receive, open, and respond to alerts simultaneously.

If members check messages late or at varying times, real-time attendance tracking will be inaccurate or incomplete right before the meeting start time.

- **Broad Communication Reach vs. Strict Privacy Constraints:** Expanding reach to ensure no member is missed can conflict with access restrictions. Ensuring all local members receive alerts while tightly locking down contact lists—especially for apprentices—requires strict authorization boundaries so visibility is not exposed across local jurisdictions.

User prompt: Given that message and these numbers: 43 locals, 187,000 members total, largest local 22,400 members, push notifications silently fail 5 to 10 percent of the time, members can be offline for hours or days. List every place the message is unclear or underspecified. Who exactly this is for, just Local 27 or all 43 locals. What 'immediately' means given the offline reality. Whether confirming attendance is required or optional. What counts as done for a callout. For each one, propose the most reasonable assumption and explain why, compared to the alternatives

Response: Unclear and Underspecified Operational Requirements

Here is every area where the request lacks key technical and operational specifications, along with the most reasonable assumption for each.

1. Scope & Scale: Is this just for Local 27 or all 43 locals (187,000 members)?

- **Unclear aspect:** The user mentions Local 27 specifically, but systemic delivery issues (push notification failures, offline workers) impact all 43 locals and 187,000 total members across the organization.
- **Proposed Assumption:** Build multi-tenant infrastructure designed for all 43 locals and 187,000 members, scoped initially with Local 27 as the launch baseline.
- **Why this beats alternatives:**
 - *Alternative A (Build exclusively for Local 27):* Creates isolated tech debt. Hardcoding data schemas or notification pathways for one local of up to ~22,400 members makes scaling to the remaining 42 locals expensive later.
 - *Alternative B (Build for all 43 immediately without scoped roles):* Overcomplicates initial deployment. Designing system permissions and tenancy globally from day one ensures security and scale, while launching Local 27 first allows real-world validation.

2. Time-to-Delivery: What does "immediate delivery" mean given the offline reality?

- **Unclear aspect:** Emergency callouts demand immediate delivery, but members frequently work in basements, elevator shafts, or rural job sites without cellular signal for hours or days. Additionally, primary push notifications fail silently 5% to 10% of the time.
- **Proposed Assumption:** Define "immediate delivery" as **multi-channel delivery attempted within 30 seconds of dispatch, with automatic store-and-forward fallback mechanisms for offline devices.**

- **Why this beats alternatives:**

- *Alternative A (Assume push notifications alone are sufficient):* With a 5–10% silent failure rate, push alerts alone leave up to 2,240 members uninformed in a single 22,400-member local.
- *Alternative B (Wait for connection before sending):* Relying on a single delivery pipe delays transmission unnecessarily. Combining push, fallback SMS, and an offline queue ensures that as soon as an off-grid device regains connectivity, the message drops instantly.

3. Response Obligations: Is confirming attendance mandatory or optional?

- **Unclear aspect:** The organizer needs to know who is coming before leaving the hall, but it is unclear whether members must respond to every callout or if responding is voluntary.
- **Proposed Assumption:** RSVP tracking must be **optional for members, but explicitly tracked by state** (Attending, Declined, Delivered/Unread, Undeliverable/Offline).
- **Why this beats alternatives:**
 - *Alternative A (Mandatory RSVP):* Disciplinary or mandatory response policies fail when members are off-grid or driving to job sites. It inflates false negatives and creates artificial friction.
 - *Alternative B (Simple binary Yes/No response):* Leaves the organizer guessing whether non-responders didn't see the message, had no signal, or saw it and chose not to attend. Explicitly showing delivery and connection states gives the organizer clear actionable numbers.

4. Lifecycle Definition: What counts as "done" for an emergency callout?

- **Unclear aspect:** The message does not specify when a callout moves from active to complete, or when attendance numbers freeze for hall organizers.
- **Proposed Assumption:** A callout reaches "done" state via a **hard time-bound window (e.g., meeting start time) combined with an explicit manual organizer override.**
- **Why this beats alternatives:**
 - *Alternative A (Marking "done" once 100% delivery is reached):* System will hang indefinitely because off-grid members won't receive the packet until days later.
 - *Alternative B (Auto-closing after a fixed 1-hour timer):* Fails for emergency meetings announced 30 minutes prior or scheduled for the following morning. Tying the lifecycle to the meeting start time reflects the real-world operational deadline.

5. Access Boundaries: What constitutes cross-local visibility for wireman apprentices?

- **Unclear aspect:** The request asks whether members outside Local 27 can see wireman apprentice contact info, but does not define who *should* have access across jurisdictions.

- **Proposed Assumption:** Enforce strict **Role-Based Access Control (RBAC)** where apprentice PII (phone, email, address) is completely hidden from non-Local 27 members and restricted strictly to authorized Local 27 officers and designated training directors.
 - **Why this beats alternatives:**
 - *Alternative A (Global member directory):* Exposes contact details across all 187,000 members, raising severe privacy concerns and potential spam/harassment risks for apprentices.
 - *Alternative B (Complete lockdown hiding apprentices from everyone):* Prevents local union stewards and hall dispatchers from reaching apprentices for job assignments and safety notices.
-

User prompt: I think there is a real access control problem in this message. Denise asks if members outside her local can see the wireman apprentices' contact info, and frames it like a small cleanup task. But if that is true right now, it means one local's member data, name, contact info, maybe classification, is visible across local boundaries. That is exactly what Rule 1 is supposed to stop, and by her own account it already happened once during onboarding, not as a hypothetical. Do you read it the same way, or am I putting too much weight on it? What is the real impact if it is true, at the scale of 187,000 members across 43 locals?

Response: You are not putting too much weight on it at all. In fact, you are identifying a critical **cross-tenant data breach** that is currently being mischaracterized as a minor UI cleanup.

If members outside Local 27 can see wireman apprentices' contact information, **the system's multi-tenant isolation boundaries are actively broken.**

Here is an analysis of why this is a major security vulnerability and the cascading impact it carries at the scale of 187,000 members across 43 locals.

The Architecture Failure: Default-Open Cross-Tenant Access

In a multi-local organization, **each local must act as a distinct tenant boundary.**

If an onboarding incident allowed a member from Local A to view PII (Personally Identifiable Information) of an apprentice in Local B, one of two fundamental architectural flaws exists:

1. **Global Directory Default:** The user directory was modeled globally (all 187,000 members in one queryable pool) rather than isolated by Local ID.
2. **Broken Role-Based Access Control (RBAC):** Member permissions were designed to grant read access across all member objects without scoping the query context to `tenant_id == user.local_id`.

Downplaying this as "something someone mentioned during onboarding" is a classic operational trap: mistaking a structural authorization bug for a minor UI preference.

The Real Impact at Scale (187,000 Members across 43 Locals)

1. Targeting, Poaching, and Unregulated Dispatch

In organized labor, jurisdiction and dispatch rules are strictly governed by collective bargaining agreements.

- **The Vulnerability:** If contractors, business agents, or members from external locals have access to a searchable database of all apprentices across 43 locals, they can bypass local hall dispatch channels to solicit workers directly.
- **The Impact:** Under-the-table job offers, jurisdictional disputes between locals, and undermining the local hall's authority over job assignments.

2. Targeted Harassment, Spam, and Phishing Vectors

Apprentices are often the most vulnerable demographic within a trade union—they are newer, less familiar with union policies, and frequently on active job sites.

- **The Vulnerability:** A single compromised account or malicious internal user anywhere in the 187,000-member network instantly exposes every apprentice's personal phone number, home email, and home address.
- **The Impact:** Smishing attacks, fake callout scams, targeted anti-union campaigns, or personal harassment without any technical barrier to stop it.

3. Breach of Privacy Laws & Union Liability

Contact details paired with worker classifications (e.g., "Wireman Apprentice") constitute sensitive employment data.

- **The Vulnerability:** Exposing private personal data across organizational boundaries without explicit consent violates fundamental data privacy regulations and internal union governance rules.
- **The Impact:** Legal liability for the international/parent body, regulatory fines, and severe loss of trust from the membership toward leadership right before sensitive contract negotiations.

The Operational Takeaway

Denise framed this as a check-box question ("I want to make sure that's not happening"), but from an engineering perspective, **this is a Severity-1 security audit mandate.**

Before building new features (like callouts or attendance tracking), the existing API endpoints, database queries, and directory rules must undergo an immediate access audit to lock down cross-tenant visibility.

User prompt: "Give me three questions I would ask Denise if I could, ranked by how much each would change the design. For example, is RSVP confirmation required before a callout or just nice to have. Does 'everyone' in a callout ever mean across locals. What delivery latency counts as

acceptable given the offline constraint. For each question, tell me what I should assume instead since she will not answer, and why that assumption holds up

Response: 1. "When an emergency callout is sent, is member response/RSVP mandatory, or purely informational?"

- **Design Impact: Highest.** This single answer dictates whether you are building a passive broadcast delivery engine or a high-throughput, stateful transactional system. A mandatory system requires enforcing response deadlines, managing queue states (Unread, Received, Acknowledged, Declined), building retry workflows, and handling dispute trails if a member claims they never received a mandatory notice.
- **Safe Assumption: Assume RSVP is strictly optional and informational.**
- **Why it holds up:** You cannot legally or practically compel a member to respond when they are off-grid in a basement, driving, or off the clock. Expecting 100% mandatory compliance on mobile devices across 187,000 blue-collar members creates massive operational noise and false failure alerts. Designing the UI to show delivery confidence states (Delivered, Pending/Offline, Responded) provides the organizer with accurate headcount visibility without breaking system workflows when members don't interact.

2. "Does 'everyone' in an emergency callout ever mean broadcasting across multiple locals simultaneously?"

- **Design Impact: High.** Broadcaster scope defines whether notification queues, database locks, and delivery pipelines are isolated to single tenant partitions (~22,400 max members) or must handle international multi-tenant broadcasts across all 43 locals (187,000 members simultaneously). Multi-local broadcasts risk hitting third-party API rate limits (Apple APNs, Google FCM, SMS aggregators) and drastically alter architectural queue management.
- **Safe Assumption: Assume emergency callouts are strictly scoped to a single local by default, with multi-local capability restricted to explicit regional super-admins.**
- **Why it holds up:** Union governance and dispatch authority operate almost entirely at the local level (Local 27 handles Local 27's contractors). Cross-local emergency meetings are rare edge cases. Scoping the default pipeline to single-local tenant boundaries keeps notification burst volumes manageable and prevents one local from starving the delivery queues of another.

3. "What maximum delivery latency is acceptable for members who are currently online versus those working off-grid?"

- **Design Impact: Medium.** This determines your fallback architecture. If "immediate" means within 10 seconds for online users, standard push services with a SMS fallback pipeline work. If it means within 1 second across all channels, you need dedicated persistent WebSocket connections and high-priority carrier short-codes, which significantly increases infrastructure costs.
- **Safe Assumption: Assume a 30-second multi-channel fanout budget for connected devices, with an asynchronous store-and-forward queue for offline devices that flushes instantly upon reconnecting.**

- **Why it holds up:** In emergency callouts, seconds matter for members who are currently reachable, but physics limits delivery to members working in signal-dead zones. Expecting zero-latency delivery to off-grid workers is impossible. A hybrid model—delivering via push/SMS within 30 seconds to active devices and staging an offline message queue for re-entry into cell coverage—balances real-world trade union working conditions with technical constraints.
-